

DLP Pattern & Sanitization Specification

What Aegis treats as sensitive, what the gateway does when it finds it, and how detection quality is proven.

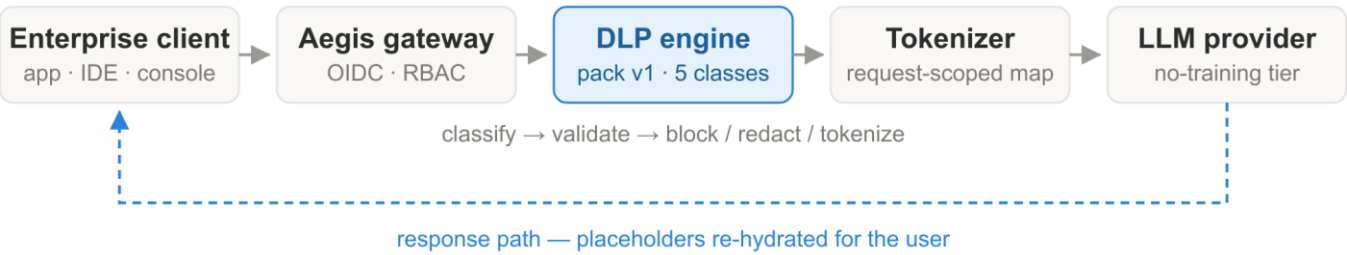
DOCUMENT	OWNER	PHASE	CLASSIFICATION
AEGIS-SEC-DLP-001	Abdullah Zubair	Phase 1 — Foundation	Internal /
v1.0 · 17 Aug 2026	Cybersecurity Engineer	Weeks 1–4	Confidential

1 Purpose & scope

Aegis is a centralized proxy between O&G endpoints and third-party LLMs. This document defines the sanitization contract that makes that proxy safe: the sensitive-content classes, the enforcement action for each class, the pattern pack that detects them, and the measurable quality bar the engine must clear before Phase 1 exit.

It governs every prompt, system message, and tool payload on the request path, and every document entering the RAG ingestion pipeline (see AEGIS-SEC-VDB-003). Authentication and model routing are out of scope and remain owned by the gateway pipeline.

2 Where sanitization happens



3 Classification & action matrix

CLASS	CONTENT	ACTION	REVERSIBLE	ALERT
C1 Secrets	API keys, private keys, JWTs, DB connection strings, cloud credentials	Block	No	Security + manager
C2 Financial	Financial account identifiers, payment card numbers, IBANs, and financial records containing combinations of financial identifiers and transaction data.	Tokenize	On response	Aggregate only

CLASS	CONTENT	ACTION	REVERSIBLE	ALERT
C3 PII	Names with identifiers, national IDs, emails, phones, addresses	Tokenize	On response	Aggregate only
C4 Proprietary code	Internal repositories, large code spans, internal hostnames	Redact + warn	No	None
C5 Project confidential	Document refs, unreleased roadmap, client and partner names	Redact + warn	No	None

4 Detection layers

Regex alone over-blocks and under-detects. Four layers run in order, and a match is only acted on after validation.

LAYER	METHOD	CATCHES WHAT REGEX CANNOT
1. Format rules	Compiled regex over prompt, attachments, and tool arguments	—
2. Validators	Luhn for card numbers, mod-97 for IBAN, checksum for IDs, Shannon entropy scoring is used as a candidate signal and never serves as the sole basis for blocking.	Kills most false positives: order numbers, hashes, version strings
3. Local NER	On-premise model, no external calls	People, organisations, locations in free text
4. Lists & glossary	Internal domain deny-list, project code-name glossary, public-reference allow-list	Context-specific confidential terms

5 Tokenization contract

- Replace each match with a stable placeholder, for example `[[PII_EMAIL_7f3a]]`, so the model keeps coreference and the answer stays useful.
- Hold the mapping in a request-scoped, in-memory vault keyed by request ID, encrypted with the tokenization DEK; TTL equals the request lifetime.
- Re-hydrate on the response path only, for the originating session. Never persist plaintext mappings to logs, traces, or disk.

6 Pattern pack v1

```
# C1 secrets — block request, alert security
AWS_ACCESS_KEY  AKIA[0-9A-Z]{16}
GENERIC_API_KEY  (?i)(api[_-]?key|secret|token)\s*[:=]\s*["']?[A-Za-z0-9\_-]{20,}
PRIVATE_KEY_BLOCK  -----BEGIN (RSA |EC |OPENSSH )?PRIVATE KEY-----
JWT_CANDIDATE    eyJ[A-Za-z0-9_-]{10,}\.[A-Za-z0-9_-]{10,}\.[A-Za-z0-9_-]{10,}
JWT-shaped matches are treated as C1 candidates and must pass structural validation before enforcement. Signature
verification is not required for detection because an unsigned or unverifiable JWT may still contain sensitive claims.
DB_CONN_STRING   (?i)(postgres|mysql|mongodb)(\+srv)?(?:/[^\s:@+:\^\\s@]+@
# C2 / C3 identifiers — tokenize, validate before acting
PAN              \b(?:\d[-]*?){13,16}\b + Luhn
IBAN             \b[A-Z]{2}\d{2}[A-Z0-9]{11,30}\b + mod-97
EMAIL           \b[\w.+-]+@[ \w.-]+\.[\w.]{2,}\b
PHONE_INTL      \+\d{1,3}[\s-]?\d{6,12}
NATIONAL_ID      country-specific national identifier patterns maintained as versioned rules within the pattern pack; each
pattern includes its applicable country/format and validation method. Initial patterns may cover known deployment countries
and are extended through the signed pattern-pack update process without requiring gateway redeployment.
# C4 / C5 proprietary — redact and warn the user
INTERNAL_HOST    (?i)\b[\w-]+\.(internal|corp|og-net)\b
DOC_REF          (?i)\bO&G-[A-Z]{3,10}-[A-Z]{3,6}-\d{4}-V\d+\b
CODE_SPAN_LARGE  heuristic: code span >400 characters or >25 lines, forwarded to contextual classification.
```

Shipped as signed, versioned config in Git (dlp-pack-v1.yaml) and hot-reloaded, so a bad pattern is rolled back without a gateway redeploy.

7 Acceptance criteria for Phase 1 exit

MEASURE	TARGET	EVIDENCE
Recall on C1 secrets	0.98 or better	Regression suite — QA
Overall false-positive rate	2% or lower	Labelled corpus, weekly report
Added latency, p95	Under 50 ms	Load test, Phase 3 gate
Behaviour on engine error	Fail closed, request blocked	Fault-injection test
Pattern rollback time	Under 5 min, no redeploy	Hot-reload drill

Bypass techniques — homoglyphs, base64, zero-width characters, and secrets split across turns — become permanent regression cases owned by the QA lead.

Open decision before build freeze: confirm with the Team Lead that hard-blocking C1 is acceptable to the business, and name the approver for tokenize-versus-block on C3 PII.

Cryptographic Key Management Runbook

Key hierarchy, custody rules, and the rehearsed procedures for rotating, revoking, and recovering every key Aegis depends on.

DOCUMENT	OWNER	PHASE	CLASSIFICATION
AEGIS-SEC-KMS-002 v1.0 · 17 Aug 2026	Abdullah Zubair Cybersecurity Engineer	Phase 1 — Foundation Weeks 1–4	Internal / Confidential

1 Purpose

Aegis holds the credentials that reach every third-party model and the keys that protect the enterprise knowledge base. This runbook defines one key hierarchy, assigns custody, and turns rotation and revocation into rehearsed procedures rather than incident-time improvisation.

2 Key hierarchy

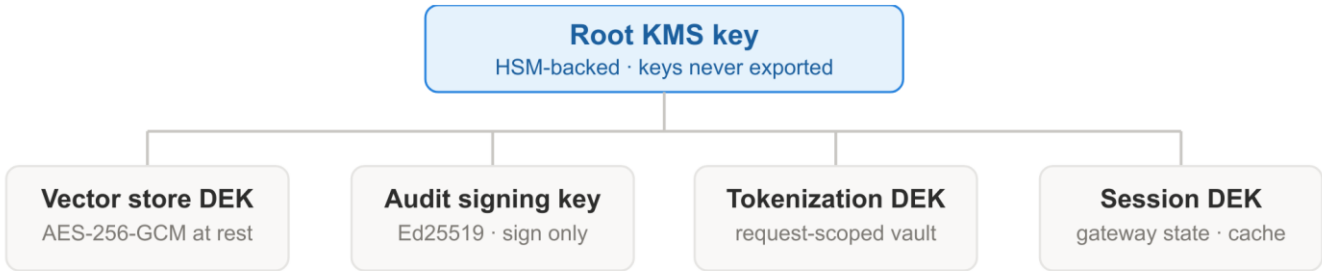


Fig. 1 — Envelope encryption: one root key per environment, one data key per purpose, so a single compromise is never total.

LLM provider credentials sit outside this tree, in the secrets manager. Workloads receive them through short-lived OIDC federation — never from environment files, container images, or source control.

3 Key inventory register

KEY	ALGORITHM	ROTATION	BLAST RADIUS IF COMPROMISED
Root KMS key	AES-256, HSM-resident	Annual	All Aegis data at rest
Vector store DEK	AES-256-GCM	180 days	Knowledge base and snapshots
Audit signing key	Ed25519, sign only	365 days	Integrity proof of the audit trail
Tokenization DEK	AES-256-GCM	180 days	Request-scoped tokenization mappings only
Provider credentials	Vendor bearer tokens	90 days	Model spend and vendor-side abuse
Service certificates	mTLS, internal CA	90 days	Gateway to vector store data path

4 Transport & storage standards

CONTROL	REQUIREMENT
In transit, external	TLS 1.3 only; no downgrade, and no plaintext listener on any interface
In transit, internal	mTLS between gateway, vector store, and ingestion workers, pinned to the internal CA
At rest	AES-256-GCM with a distinct DEK per data class; snapshots and backups inherit the same key
Identity	Short-lived workload identity through OIDC federation; static production credentials are prohibited
Human access	No engineer holds a production key. Break-glass is two-person, time-boxed, and fully logged

5 Procedure — zero-downtime rotation

1. Raise a change record and confirm the current key version from the register.
2. Create the new key version in the KMS; do not disable the old version yet.
3. Publish both versions to the gateway so it can verify with either during the overlap window.
4. Switch write and sign operations to the new version; monitor error rates for 30 minutes.
5. Re-encrypt or re-wrap stored data where the DEK changed, then verify a sample read.
6. Disable the old version, schedule its destruction after the retention window, update the register, and close the change record.

Prohibited, without exception: keys in source control, prompts, logs, or traces · shared credentials across environments · long-lived personal access tokens in production · disabling secret scanning to unblock a build.

6 Procedure — suspected exposure

1. Revoke the affected credential at the source immediately; do not wait for the change window.
2. Rotate the key, then invalidate every session and cached token derived from it.
3. Query the audit trail for use of the key in the exposure window (see AEGIS-SEC-AUD-004).
4. Notify the Team Lead within one hour with scope, affected data classes, and containment status.
5. File the incident record, retain evidence, and add a check so the same exposure path is detected automatically.

7 Phase 1 evidence checklist

- ☐ Root key and four DEKs created, each mapped to a purpose in the register
- ☐ All provider credentials moved into the secrets manager and removed from configs and repositories
- ☐ Secret scanning enforced in CI, with a blocking rule on commit and merge
- ☐ mTLS enabled between gateway components and verified with a failed-handshake test
- ☐ One full rotation drill completed and timed, evidence attached to this runbook
- ☐ Break-glass path tested with two approvers and reviewed in the audit trail

Phase 3 relevance: the register, the rotation drill record, and the break-glass log are the three artefacts requested at the final security sign-off. Keep them current from week 1 rather than reconstructing them in week 12.

Vector Database Security Standard

Mandatory controls for the private RAG stores (Qdrant / Milvus) that hold the enterprise knowledge base, each with the verification it requires.

DOCUMENT	OWNER	PHASE	CLASSIFICATION
AEGIS-SEC-VDB-003 v1.0 · 17 Aug 2026	Abdullah Zubair Cybersecurity Engineer	Phase 2 — RAG & Analytics Weeks 5–8	Internal / Confidential

1 Why this standard exists

The vector store is the highest-value asset in Aegis: it holds enterprise knowledge in a form that is trivially queryable and trivially leakable. A retrieval bug is not a bug, it is a disclosure. Every control below is mandatory before a production corpus is ingested, and each has a named verification so compliance is demonstrable rather than assumed.

2 Platform controls

ID	REQUIREMENT	VERIFICATION
VDB-01	No public endpoint. Private subnet only, ingress restricted to the gateway and ingestion workers	External port scan returns no reachable service
VDB-02	Authentication enforced on every node (Qdrant API key or JWT, Milvus RBAC users); default open mode explicitly disabled	Unauthenticated request returns 401 in a recorded test
VDB-03	mTLS on the data path and on cluster-internal replication traffic	Handshake without a client certificate is rejected
VDB-04	Encryption at rest for segments, snapshots, and backups using the vector store DEK	Key reference confirmed in the register, AEGIS-SEC-KMS-002
VDB-05	Rate limits and result-size caps per identity, to blunt mass extraction and embedding-inversion probing	Load test shows throttling before the extraction threshold
VDB-06	Backup and restore tested end to end; snapshot access logged and alerted	Timed restore drill into an isolated environment

3 Data-layer controls

ID	REQUIREMENT	VERIFICATION
VDB-07	Every chunk carries access metadata written at ingest time; unlabelled chunks are rejected	Schema validation in the ingestion pipeline
VDB-08	Retrieval is filtered server-side by the caller's RBAC claims. Filtering after retrieval in application code is prohibited	Automated test asserts the filter on every RAG call
VDB-09	Separate collections per sensitivity tier for HR, legal, and finance corpora	Collection inventory reviewed with the Team Lead
VDB-10	Hard-delete path removes the document's vectors, stored chunks, retrieval caches, derived indexes, and any other persisted representation used by the retrieval path.	Withdrawn test document is unanswerable within 15 minutes across the vector store, retrieval cache, derived indexes, and any other retrieval-layer representation.

4 Chunk payload & enforced filter

Sensitivity tiers define retrieval authorization independently of DLP classification. DLP classification identifies the type of sensitive content detected, while the sensitivity tier determines whether a caller is authorized to retrieve the content.

Sensitivity tiers: public, internal, confidential, restricted. Each caller is assigned an explicit set of tiers they are authorized to retrieve.

REQUIRED PAYLOAD AT INGEST

```
{
  "source_uri": "...",
  "content_sha256": "...",
  "classification": "C3",
  "sensitivity_tier": "confidential"
  "acl_roles": ["finance"],
  "owner": "dept-finance",
  "dlp_pack": "v1.0",
  "ingested_at": "2026-08-17"
}
```

SERVER-SIDE FILTER, EVERY QUERY

```
filter:
  must:
    - key: acl_roles
      match:
        any: $caller.roles
    - key: sensitivity_tier
      match:
        any: $caller.allowed_sensitivity_tiers
```

A query that arrives without the filter is rejected and pages the on-call engineer. The same DLP engine runs over documents **before** embedding, so secrets never become vectors — ingest-time classification is what makes the filter above meaningful.

5 Threat cases and required tests

THREAT	TEST	OWNER
Low-privilege user retrieves high-classification chunks	RBAC bypass suite, one case per tier	Identity & Access / IAM Engineer

THREAT	TEST	OWNER
Prompt injection inside an ingested document redirects the model or exfiltrates context	Poisoned-document corpus with assertions on output	Application Security Engineer
Cross-tenant similarity leakage from a shared collection	Nearest-neighbour probe across tenants	AI/ML Security Engineer
Snapshot or backup read without credentials	Direct object-store access attempt	Cloud / Infrastructure Security Engineer
Withdrawn document still answerable from cache or index	Delete-then-query regression case	RAG / Platform Engineer

6 Phase 2 exit conditions

- ☐ All ten controls verified on every cluster, with the verification artefact stored against the control ID
- ☐ The five threat tests running green in CI, not as one-off manual checks
- ☐ Ingest pipeline rejecting unlabelled or unscanned documents by default
- ☐ Every exception recorded in the risk register with an owner and an expiry date

No corpus goes live on an unverified cluster. Where a control cannot be met in Phase 2, the corpus stays out of the store until the exception has a dated remediation plan agreed with the Team Lead.

Audit Logging & Security Telemetry Spec

The evidence layer of Aegis: what every request records, how the trail is made tamper-evident, and which anomalies raise an alert.

DOCUMENT	OWNER	PHASE	CLASSIFICATION
AEGIS-SEC-AUD-004 v1.0 · 17 Aug 2026	Abdullah Zubair Cybersecurity Engineer	Phases 1–3 Sign-off in week 12	Internal / Confidential

1 Principle — hashes, not bodies

The audit trail must prove what happened without becoming a second copy of the sensitive data it protects. Aegis therefore records metadata, classification decisions, and content hashes — never prompt or completion bodies. An auditor can establish who asked what kind of question, which policy fired, and where the request went, and still learn nothing they were not entitled to see.

2 Audit event schema

```
{
  "event_id": "uuid-v7",
  "ts": "2026-08-17T09:41:22.104Z",
  "actor": { "user_id": "...", "roles": ["finance"], "dept": "..."},
  "session_id": "...",
  "route": { "provider": "vendor-a", "model": "...", "region": "eu" },
  "prompt_sha256": "...", // hash only, never the text
  "dlp": { "pack": "v1.0", "classes": ["C3"], "action": "tokenize",
    "match_count": 2, "latency_ms": 31 },
  "rag": { "collections": ["finance"], "chunks": 6, "filter": "enforced" },
  "tokens": { "in": 812, "out": 240, "cost_usd": 0.0141 },
  "outcome": "allowed", // allowed | blocked | redacted | error
  "prev_hash": "...", // hash chain over the preceding event
  "sig": "ed25519:..."
}
```

Emitted for **every** request, including blocked and errored ones. A missing event is itself a security finding, and gaps in the sequence are alerted on. Each request receives exactly one terminal audit event identified by a unique event_id. Retries, internal processing attempts, and downstream failures must not create multiple terminal events for the same request. Duplicate or missing terminal events are treated as audit-integrity findings.

3 Integrity requirements

- Append-only sink, write-once storage, with no delete or update grant for any application role.
- Hash chain across consecutive events; a daily root hash is signed with the audit key and stored separately.
- Clock discipline through NTP, with skew above two seconds raising an alert, so ordering stays defensible.
- Verification job replays the chain nightly and reports the first divergence with its event ID.

4 Retention & access

STREAM	RETENTION	WHO CAN READ IT	CONTAINS SENSITIVE TEXT
Security audit events	13 months	Security, internal audit	No — hashes only
DLP decision log	13 months	Security	No — class and count only
Gateway access log	90 days	Security, platform on-call	No
Usage & cost telemetry	24 months	Analytics, Team Lead	No — aggregate counters

Access to any stream is itself audited. Export requires Team Lead approval and is recorded against the requesting identity.

5 Anomaly rules v1

SIGNAL	CONDITION	SEVERITY	RESPONSE
Secret-block burst	3 or more C1 blocks by one actor within 10 minutes	High	Page security, notify manager
Retrieval volume spike	Chunk retrieval above 5× the actor's 30-day baseline	Medium	Throttle, review session
Filter bypass attempt	Any RAG query lacking the enforced RBAC filter	High	Reject, page on-call
Off-hours access	Sensitive-collection reads outside working hours	Medium	Daily review queue
Audit gap	Chain divergence, or requests without a matching event	High	Freeze release, investigate

6 Security console panels

Built with the UX and analytics leads on the Phase 2 monitoring dashboards, so security views share one data model with usage reporting.

- ☐ DLP actions over time, split by class, with drill-down to the rule that fired
- ☐ Top blocked actors and departments, ranked, with 30-day trend
- ☐ False-positive review queue, feeding pattern-pack tuning

- ☐ Retrieval heat map by collection and sensitivity tier
- ☐ Engine health: p95 added latency, error rate, fail-closed events
- ☐ Audit chain status, with last verified root hash and timestamp

7 Phase 3 security sign-off pack

1. Penetration test report, with every high and critical finding closed or formally accepted.
2. DLP effectiveness report: recall, false-positive rate, and p95 latency against the targets in AEGIS-SEC-DLP-001.
3. Key management evidence: register, rotation drill record, break-glass log.
4. Vector store control matrix, all ten controls verified per cluster.
5. Audit integrity proof: 30 consecutive days of verified chain roots.

Definition of done for the security workstream: Every production request produces exactly one terminal signed audit event, including blocked, failed, and completed requests. The event is uniquely correlated to the originating request through the request ID and event_id.

PREPARED BY

Abdullah Zubair

Cybersecurity Engineer